

電子化鑑定考試系統

本說明包含考試重要資訊，請仔細閱讀。

各項試場規定參照公務人員考試法第二十二條辦理。

請應考人確實遵守。

- 本次考試採用電腦化實機測驗，應考人請依試題要求，使用滑鼠及鍵盤操作填寫應試。
各科目之題型說明及計分方式，請仔細閱讀注意事項。
- 試題文字以中文呈現，專有名詞加註英文原文，若有非選擇題部分，應考人以中文回答即可。
- **應考人如對試題內容、題意有疑義，請於考試當天該科鑑定進行期間且仍在試場內，向監試人員提出申請，並填具【疑義考題紀錄單】。**



有關試題疑義申請相關詳細規定，將依據能力鑑定簡章附錄《iPAS經濟部產業人才能力鑑定 疑義考題處理須知》，敬請應考人留意相關規定，以確保自身權益。

注意事項：

請仔細閱讀該考科之注意事項

(各科目內容不同，請以實際考試資料為準)

進入試場後嚴禁使用手機、
智慧型手錶等電子通訊連網設備。



輸入身分證字號

Ver:20.7.1

考生帳號：

登錄

取消

點按「登錄」進入系統

請於考試帳號中輸入身分證字號，並點按登錄按鈕進入系統

登入完成後，
請**確認考試科目**無誤，
並請仔細閱讀注意事項。

閱讀完成後請點按**開始**按鈕，
即可進行本次考試。

閱讀完成後點按**開始**，
進行試題讀取

[級別] 考試科目

測驗注意事項

身分證統一編號:A243 姓名:A243

一、本試卷試題，為學科試卷，含單複選題加情境題組題，共40題，共佔100%，每題2.5分(答錯不倒扣)，總分共計100分，測驗時間90分鐘。

二、本試題 0為阿拉伯數字，O為英文字母，作答時請先確認。

三、學科試卷中滑鼠左右鍵位之選項，請以右手操作作答。

四、有問題請舉手發問，切勿私下交談。

請仔細閱讀該考科
之注意事項
(各科目內容不同，
請以實際考試資料為準)

開始

試卷資料已載入完成，請點擊「開始」按鈕進行計時測驗。

核對考試科目
及基本資料



學科測驗

[級別] 考試科目 A243 / A243 86:39 / 90:00 結束測驗

◀ 上一題 下一題 ▶ 不作答 試題標記 試題總覽 查看附圖

2.公司在招募新員工時，若打算在網頁上公布錄取榜單，下列敘述何者「不」正確？

- ☐ (A) 公布招募新進員工之榜單，應先依法取得當事人之書面同意
- ☐ (B) 自然人之姓名，屬個人資料之範疇，故公布榜單之行為必須符合個資法規範
- ☐ (C) 若取得當事人書面同意之作業有窒礙難行之處，採「匿名化」、「去識別化」方式公布榜單，為較適切的作法
- ☒ (D) 因同名同姓的人很多，若只公告單一項姓名資料，並無法直接識別出本人，不

單選題
(圓形按鈕)

題目類型：單選題/複選題

學科測驗

[級別] 考試科目 A243 / A243 85:41 / 90:00 結束測驗

◀ 上一題 下一題 ▶ 不作答 試題標記 試題總覽 查看附圖

12. 某中小企業資訊部門之業務執掌包含程式開發、程式上線、應用程式管理以及資料庫管理等，該公司因故必須縮減資訊部門人力，若您是該企業之資訊部門主管，下列哪些項目之處理較能降低資安風險的發生？（複選）

- ☐ (A) 將部分資安工作移轉至其他業務單位
- ☒ (B) 增加業務活動之監視紀錄
- ☒ (C) 增加資安稽核頻率
- ☒ (D) 實施工作輪調

複選題
(方形按鈕)

選擇題請選擇滑鼠左鍵作答，

單選題限制點選單一答案，選擇區塊為圓形按鈕，

複選題可勾選兩項以上之答案，選擇區塊為方形按鈕



學科測驗

[級別] 考試科目 A243 / A243 86:39 / 90:00 結束測驗

◀ 上一題 下一題 ▶ 不作答 試題標記 試題總覽

2.公司在招募新員工時，若打算在網頁上公布錄取榜單，下列敘述何者「不正確」？

- ☐ (A) 公布招募新進員工之榜單，應先依法取得當事人之書面同意
- ☐ (B) 自然人之姓名，屬個人資料之範疇，故公布榜單之行為必須符合個人資料保護法之規定
- ☐ (C) 若因取得當事人書面同意之作業有窒礙難行之處，採「匿名化」、「去識別化」方式公布榜單，為較適切的作法
- ☒ (D) 因同名同姓的人很多，若只公告單一項姓名資料，並無法直接識別出本人，不需取得當事人之書面同意

可使用上一題及下一題進行操作

上方列出本次測驗科目、基本資料及測驗時間，
可使用「上一題」及「下一題」按鈕切換作答題目

上方提示測驗科目、基本資料
及測驗時間（倒數時間）

學科測驗

[級別] 考試科目 A243 / A243 86:39 / 90:00 結束測驗

◀ 上一題 下一題 ▶ 不作答 試題標記 試題總覽 查看附圖

2.公司在招募新員工時，若打算在網頁上公布錄取榜單，下列敘述何者「不」正確？

- ☐ (A) 公布招募新進員工之榜單，應先依法取得當事人之書面同意
- ☐ (B) 自然人之姓名，屬個人資料之範疇，故公布榜單之行為必須
- ☐ (C) 若因取得當事人書面同意之作業有窒礙難行之處，採「匿名化」或「去識別化」方式公布榜單，為較適切之作法
- ☒ (D) 因同名同姓的人很多，若只公告單一項姓名資料，並無法直接識別出本人，不需取得當事人之書面同意

可標記特定題目

可清空作答資料

不作答按鈕可清空作答資料，
試題標記可標記特定題目，
標記內容僅供應考生參考，不影響評分結果



學科測驗

[級別] 考試科目 A090 / A090 89:10 / 90:00 結束測驗

◀ 上一題 下一題 ▶ 不作答 試題標記 試題總覽 查看附圖

12. 依據附圖所示之結果，此為OWASP Top 10 - 2017文件敘述的何項風險分類？

☐ (A) Cross-Site Scripting (XSS)

☐ (B) XML External Entities (XXE)

☐ (C) Sensitive Data Exposure

☐ (D) Security Misconfiguration

Request Response

Raw Params Headers Hex ViewState

POST request to /index/Index.aspx

Type	Name
Cookie	
Cookie	
Cookie	RememberAccount
Cookie	

查看附圖 題號：12

Request Response

Raw Params Headers Hex ViewState

POST request to /index/Index.aspx

Type	Name	Value
Cookie		
Cookie		
Cookie	RememberAccount	isRememberMe=YES&UserAccount=S1
Cookie		

如題目有附圖內容，
可以點擊**查看附圖**按鈕放大圖片瀏覽



學科測驗

[級別] 考試科目 A243 / A243 86:39 / 90:00 結束測驗

◀ 上一題 下一題 ▶ 不作答 試題標記 試題總覽 查看附圖

2.公司在招募新員工時，若打算在網頁上公布錄取榜單，下列敘述何者「不」正確？

- ☐ (A) 公布招募新進員工之榜單，應先依法取得當事人之書面同意
- ☐ (B) 自然人之姓名，屬個人資料之範疇，故公布榜單之行為必須符合個資法規範
- ☐ (C) 若因取得當事人書面同意之作業有窒礙難行之處，經「匿名化」後再公布榜單，為較適切的作法
- ☒ (D) 因同名同姓的人很多，若只公告單一項姓名資料，即可避免洩漏當事人之書面同意

可將內文文字放大或縮小

點擊放大按鈕或縮小按鈕，
可將內文文字放大或縮小瀏覽

學科測驗

[級別] 考試科目 A243 / A243 86:39 / 90:00 結束測驗

下一題 不作答 試題標記 試題總覽 查看附圖

綠：有作答 黃：有註記 紅：未作答

2. 公司在招募新員工時，若打算在網頁上公布錄取榜單，下列敘述何者「不」正確？

人之書面同
單之行為必
處，採「匿
料，並無法

試題總覽

題號 題目

1. 在駭客工具中，常見到中國菜刀（China Chopper）或相似工具其主要手法為？

2. 通用漏洞評分系統（Common Vulnerability Scoring System, CVSS）是一個可衡量漏洞嚴重程度的公開標準。CVSSv3以基本指標群（Base metric group）、暫時指標群（Temporal metric group）及環境指標群（Environmental metric group）等3個群組來進行判斷。關於基本指標群，下列何者「不」是其考量因素？

3. 關於安全軟體發展生命週期（Security Software Development Lifecycle, SSDLC），下列敘述何者正確？

4. 磁碟陣列（RAID）是一種即時備援與資料復原技術，它主要使用多個磁碟進行資料複製的檔案系統，下列何種規劃「不」能避免因單一磁碟故障而造成資料損毀的能力？

5. 安全事件緊急應變處置最重要目的是下列何者？

6. 關於編碼、加密與雜湊機制，下列敘述何者正確？

7. 關於XML External Entity（XXE）Injection的防護，下列防護機制何者較佳？

8. 公司收到主管機關要求，必須每年進行網路資安健檢，下列何者方式較「不」符合？

9. 本網站弱點掃描報告中，發現系統本身存在XSS及Open Redirect問題，可以採取下列何者方案進行修補？

10. 在日常檢查時發現10.10.1.1 (web)，10.10.1.2 (db)發現入侵警訊風險如附圖內容所示時，請問第一步應該做？

11. 如果網站遭遇入侵行為，在採取風險

12. 依據附圖所示之結果，此為OWASP

13. 關於資訊與通訊系統安全經常使用到

14. 公司資訊室主任要求MIS人員每一季

15. 依據OWASP Top 10 2017中，其A9項目

16. 網頁瀏覽器的Cookies並未使用加密保

點選各題圖示則可帶至該題

右上方圖示可切換試題總覽模式

試題總覽按鈕可以檢視整體作答情況，題號顯示綠色為有作答、黃色為有註記、紅色為未作答。點選右上方圖示可切換「試題總覽模式」；點選各題圖示時，則可以回到該題內容進行修改確認。

學科測驗

[中級-學科]資訊安全防護實務 A090 / A090 83:07 / 90:00

[級別] 考試科目

1 **結束測驗**

◀ 上一題 下一題 ▶ 不作答 試題標記 試題總覽 查看附圖

8.公司收到主管機關要求，必須每年進行網路資安健檢，下列何者方式較「不」符合？

☐ (A) 遠端網路弱點掃描 (Network Vulnerability Assessment)

☐ (B) 遠端滲透測試 (Penetration Testing)

☒ (C) 到場網頁應用程式弱點掃描 (Web Vulnerability Assessment)

☐ (D) 到場網路安全備援服務

作答完成時

當應考人作答完成時，請點選上方「結束測驗」按鈕，系統將會統計作答狀況供應考人參考。

確認無誤後，請點選「是」按鈕結束測驗，離開考場時請記得攜帶個人隨身物品及證件。

3 本次鑑定已結束
請攜帶您隨身的物品及證件，離開考試場地。

CSF測驗

⚠ 以下是您學科測驗作答情況，
正確請按「是」結束學科測驗，
錯誤請按「否」回到學科測驗。

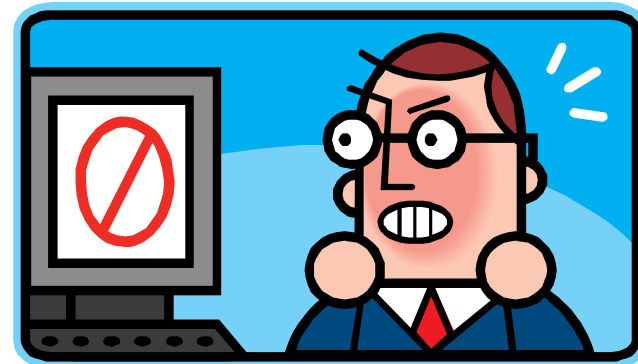
學科總題數：40
已作答題數：8
未作答題數：32

2 **是(Y)** 否(N)

確定結束 返回系統

於考試進行中，若系統發生問題，
請舉手由監試人員協助，切勿任意自行操作。
如遇空襲警報或其他緊急事故，請依照監試人員指揮處理。

感謝各位應考人的配合，
祝您考試順利。



如對說明仍有不了解的部分
請舉手詢問監試人員
將為您解答

